ISO 27001 Implementatie-roadmap

Projectplan voor certificeringsgereedheid in 6 maanden

Documentnummer	ISMS-040
Versie	1.0
Classificatie	Intern
Eigenaar	[Naam CISO / Verantwoordelijke]
Goedgekeurd door	[Naam Directie]
Datum goedkeuring	[DD-MM-JJJJ]
Volgende review	[DD-MM-JJJJ]

1. Doel

Dit document biedt een concrete, gefaseerde aanpak om [Organisatienaam] binnen 6 maanden certificeringsgereed te maken voor ISO 27001:2022. Elke fase bevat duidelijke deliverables, verantwoordelijken en mijlpalen.

2. Overzicht fasering

Fase	Maand	Focus	Resultaat
1	Maand 1	Fundament & Governance	ISMS-scope, beleid, rollen, context vastgelegd
2	Maand 2	Risicomanagement	Risicobeoordeling afgerond, SoA opgesteld
3	Maand 3	Beleid & Procedures	Alle beleidsdocumenten opgesteld en goedgekeurd
4	Maand 4	Implementatie & Techniek	Technische en organisatorische maatregelen geïmplementeerd
5	Maand 5	Bewustwording & Testen	Awareness-training, BCP-test, eerste interne audit
6	Maand 6	Audit-readiness	Management review, correctieve maatregelen, pre-audit

3. Fase 1 — Fundament & Governance (Maand 1)

Doel: De basis leggen voor het ISMS.

#	Activiteit	Deliverable	Verantwoordelijke	Deadline	Status
1.1	Directie commitment verkrijgen	Getekend commitment-statement	Directie	Week 1	☐
1.2	CISO / IS-verantwoordelijke aanwijzen	Benoemingsbrief	Directie	Week 1	☐
1.3	ISMS-scope definiëren	ISMS Scope Document (ISMS-001)	CISO	Week 2	☐
1.4	Context en belanghebbenden vastleggen	Context & Belanghebbenden Register (ISMS-035)	CISO	Week 2	☐
1.5	Informatiebeveiligingsbeleid opstellen	Informatiebeveiligingsbeleid (ISMS-002)	CISO	Week 3	☐
1.6	Doelstellingen formuleren	Doelstellingen document (ISMS-003)	CISO	Week 3	☐
1.7	Rollen en verantwoordelijkheden vastleggen	Rollen & Verantwoordelijkheden (ISMS-004)	CISO	Week 3	☐
1.8	Documentbeheerprocedure opstellen	Documentbeheerprocedure (ISMS-007)	CISO	Week 4	☐
1.9	Beleid laten goedkeuren door directie	Getekende documenten	Directie	Week 4	☐

Mijlpaal Fase 1: Directie heeft het ISMS formeel goedgekeurd, scope en governance staan.

4. Fase 2 — Risicomanagement (Maand 2)

Doel: Risico's identificeren, beoordelen en behandelen.

#	Activiteit	Deliverable	Verantwoordelijke	Deadline	Status
2.1	Asset-inventarisatie uitvoeren	Asset Register (ISMS-008)	CISO + IT	Week 5	☐
2.2	Wettelijke vereisten inventariseren	Register Wettelijke Vereisten (ISMS-038)	CISO	Week 5	☐

2.3	Risicobeoordeling uitvoeren	Risicobeoordeling & Risicoregister (ISMS-005)	CISO	Week 6-7	☐
2.4	Risicobehandelingsplan opstellen	Risicobehandelingsplan (onderdeel ISMS-005)	CISO	Week 7	☐
2.5	Statement of Applicability opstellen	SoA (ISMS-006)	CISO	Week 8	☐
2.6	Risicobehandeling laten goedkeuren	Getekend behandelingsplan	Directie	Week 8	☐

Mijlpaal Fase 2: Risicoregister is gevuld, SoA is opgesteld, directie heeft restrisico's geaccepteerd.

---

5. Fase 3 — Beleid & Procedures (Maand 3)

Doel: Alle benodigde beleidsdocumenten en procedures opstellen.

#	Activiteit	Deliverable	Verantwoordelijke	Deadline	Status
3.1	HR-beveiligingsbeleid opstellen	ISMS-009	CISO + HR	Week 9	☐
3.2	Acceptable Use Policy opstellen	ISMS-011	CISO	Week 9	☐
3.3	Toegangsbeleid opstellen	ISMS-012	CISO + IT	Week 9	☐
3.4	Wachtwoord- & authenticatiebeleid	ISMS-013	CISO + IT	Week 10	☐
3.5	Classificatiebeleid opstellen	ISMS-014	CISO	Week 10	☐
3.6	Fysiek beveiligingsbeleid	ISMS-015	CISO + Facilitair	Week 10	☐
3.7	Cryptografiebeleid	ISMS-016	CISO + IT	Week 11	☐
3.8	Patch- & kwetsbaarheidsbeheer	ISMS-017	IT	Week 11	☐
3.9	Logging & monitoring beleid	ISMS-018	IT	Week 11	☐
3.10	Incident Response Plan	ISMS-019	CISO	Week 12	☐
3.11	Business Continuity Plan	ISMS-020	CISO + IT	Week 12	☐
3.12	Alle beleidsdocumenten laten reviewen en goedkeuren	Getekende documenten	Directie + CISO	Week 12	☐

Mijlpaal Fase 3: Alle kernbeleidsdocumenten zijn opgesteld, gereviewed en goedgekeurd.

---

6. Fase 4 — Implementatie & Techniek (Maand 4)

Doel: Beleid omzetten in praktijk — technische en organisatorische maatregelen implementeren.

#	Activiteit	Deliverable	Verantwoordelijke	Deadline	Status
4.1	MFA implementeren op alle kritieke applicaties	MFA-configuratierapport	IT	Week 13	☐
4.2	Schijfversleuteling activeren op alle endpoints	Encryptie-statusrapport	IT	Week 13	☐
4.3	Vulnerability scanning opzetten (maandelijks)	Eerste scanrapport	IT	Week 14	☐
4.4	Logging centraliseren en monitoring inrichten	SIEM/log-configuratie	IT	Week 14	☐
4.5	Toegangsrechten reviewen en opschonen	Review-rapport	IT + Leidinggevenden	Week 15	☐
4.6	Backup-procedure valideren (3-2-1)	Backup-configuratierapport	IT	Week 15	☐
4.7	Fysieke beveiligingsmaatregelen controleren	Inspectieformulier	Facilitair + CISO	Week 16	☐
4.8	Clean desk / clear screen beleid uitrollen	Communicatiebewijs	CISO	Week 16	☐
4.9	Leveranciersinventarisatie en -beoordeling starten	Leveranciersregister + eerste assessments	CISO	Week 16	☐
4.10	AUP laten ondertekenen door alle medewerkers	Getekende AUP's	HR + CISO	Week 16	☐

Mijlpaal Fase 4: Technische basismaatregelen zijn geïmplementeerd, organisatorische maatregelen zijn uitgerold.

---

7. Fase 5 — Bewustwording & Testen (Maand 5)

Doel: Medewerkers trainen, plannen testen, eerste interne audit uitvoeren.

#	Activiteit	Deliverable	Verantwoordelijke	Deadline	Status
5.1	Awareness-training uitvoeren (alle medewerkers)	Trainingsregistratie + toetsresultaten	CISO	Week 17-18	☐
5.2	Eerste phishing-simulatie uitvoeren	Simulatierapport	CISO	Week 18	☐

5.3	Competentiematrix invullen	Competentiematrix (ISMS-036)	CISO + HR	Week 18	☐
5.4	Business Continuity Plan testen (tabletop)	Testverslag	CISO + IT + Directie	Week 19	☐
5.5	Backup-hersteltest uitvoeren	Hersteltest-rapport	IT	Week 19	☐
5.6	Incident Response Plan testen (tabletop)	Testverslag	CISO + IT	Week 19	☐
5.7	Interne audit uitvoeren (alle clausules)	Interne auditrapportage	CISO / Externe auditor	Week 20	☐
5.8	Correctieve maatregelen initiëren voor bevindingen	CAPA-registratie	CISO	Week 20	☐

Mijlpaal Fase 5: Eerste interne audit is afgerond, medewerkers zijn getraind, plannen zijn getest.

---

8. Fase 6 — Audit-readiness (Maand 6)

Doel: Laatste gaps dichten, management review uitvoeren, klaar voor de externe audit.

#	Activiteit	Deliverable	Verantwoordelijke	Deadline	Status
6.1	Correctieve maatregelen uit interne audit afronden	Afgeronde CAPA's	Proceseigenaren	Week 21-22	☐
6.2	KPI's en meetrapportage invullen	KPI-rapportage (ISMS-037)	CISO	Week 22	☐
6.3	Alle documentatie controleren op volledigheid	Documentenregister check	CISO	Week 23	☐
6.4	Management review uitvoeren	Management review notulen (ISMS-022)	Directie + CISO	Week 23	☐
6.5	Pre-audit review (optioneel, Annex27 dienst)	Pre-audit rapport	Lead Auditor	Week 24	☐
6.6	Resterende gaps verhelpen	Bijgewerkte documenten en registraties	CISO + IT	Week 24	☐
6.7	Certificeringsaudit aanvragen bij certificeerder	Aanvraagbevestiging	CISO	Week 24	☐

Mijlpaal Fase 6: Organisatie is certificeringsgereed. Externe audit kan worden ingepland.

---

9. Na certificering — Doorlopend onderhoud

Activiteit	Frequentie
Interne audits	Minimaal jaarlijks (alle clausules)
Management review	Minimaal jaarlijks
Risicobeoordeling actualiseren	Jaarlijks of bij significante wijzigingen
Awareness-training + phishing-simulatie	Jaarlijks + 2x simulatie
Leveranciersbeoordelingen	Conform classificatie
KPI-monitoring en rapportage	Kwartaallijks
Surveillance-audit (door certificeerder)	Jaarlijks
Hercertificeringsaudit	Elke 3 jaar

10. Veelgemaakte fouten

Fout	Hoe te voorkomen
Te laat beginnen met awareness	Start in maand 1 met communicatie, formele training in maand 5
Risicobeoordeling als papieren exercitie	Betrek IT en management actief, koppel aan echte dreigingen
SoA invullen zonder onderbouwing	Elke control in de SoA moet verwijzen naar een risico of beleidsdocument
Geen bewijsmateriaal verzamelen	Begin vanaf dag 1 met het bewaren van bewijs (logs, screenshots, getekende documenten)
Interne audit door niet-onafhankelijke auditor	De auditor mag niet zijn eigen werk auditen
Management review overslaan of uitstellen	Plan deze vroeg in — het is een harde eis

11. Projectteam

Rol	Naam	Tijdsbesteding (geschat)
Projectleider / CISO	[Naam]	8-16 uur/week

IT-beheer	[Naam]	4-8 uur/week
HR	[Naam]	2-4 uur/week (maand 1, 3, 5)
Directie	[Naam]	2-4 uur/maand (reviews, goedkeuringen)
Facilitair	[Naam]	2-4 uur (maand 4)
Externe begeleiding (optioneel)	[Annex27 / Consultant]	Naar behoefte

12. Versiebeheer

Versie	Datum	Wijziging	Auteur
1.0	[DD-MM-JJJJ]	Initiële versie	[Naam]